

RE: MSRC Case 73588 CRM:0022008796

Od Microsoft Security Response Center <secure@microsoft.com>

Do Microsoft Security Response Center <secure@microsoft.com>, kroppoloe@protonmail.ch

Data wtorek, 13 września 2022 1:27 PM

Dear Finder

Our teams have concluded that this is not a security issue because it's caused by potential fraud let-thru, instead of account compromise.

We would make the changes to reduce the per hardware ID allowed session count.

This case is now being closed.

If you have any questions or concerns please don't hesitate to contact us.

Regards

MSRC

----- Original Message -----

From: Microsoft Security Response Center

Received: Fri Aug 19 2022 11:20:50 GMT+0530 (India Standard Time)

To: <Microsoft Security Response Center>; kroppoloe@protonmail.ch; Microsoft Security Response Center; Microsoft Security Response Center

Subject: MSRC Case 73588 CRM:0022008796

Dear Finder

Thanks for the additional info.

Will get our team to review and keep you posted.

Thanks for your patience.

Regards

MSRC

----- Original Message -----

From: kroppoloe@protonmail.ch

Received: Thu Aug 18 2022 15:08:00 GMT+0530 (India Standard Time)

To: <Microsoft Security Response Center>; Microsoft Security Response Center; Microsoft Security Response Center

Subject: MSRC Case 73588 CRM:0022008796

However this mechanism still allows to make accounts from the tor network without phone verification and without a captcha and this is precisely where the vulnerability lies, as it provides one a way to make an account from the tor network without sms verification which is typically required. Also the device ticket

restrictions can be bypassed by making a different VM. The main impact of the vulnerability is not necessarily the spam ability.

Sent from Proton Mail for iOS

czw., 18 sie 2022 06:56, Microsoft Security Response Center <secure@microsoft.com> napisał(a):

Dear Finder

Our team has evaluated the finding and has come to the conclusion that obtaining the device ticket for the Windows device and using that to create an account through our Windows OOB Sign-up UX is no exploit. By design, with a Windows device ticket a limited number of account creations are allowed before the account protection mechanisms are applied during the sign-up flow. The number of sign-ups is also limited for the lifetime of a particular device.

Once those are exhausted, all the regular protections mechanisms apply.

Hence, I will close this case.

If you have any questions or more information please don't hesitate to contact us.

Regards

Neha

MSRC

----- Original Message -----

From: kroppoloe@protonmail.ch

Received: Mon Aug 08 2022 19:30:15 GMT+0530 (India Standard Time)

To: <Microsoft Security Response Center>; Microsoft Security Response Center; Microsoft Security Response Center

Subject: MSRC Case 73588 CRM:0022008796

Video attached and exploit_fixed.zip is uploaded.

Sent from Proton Mail for iOS

pon., 8 sie 2022 09:38, Microsoft Security Response Center <secure@microsoft.com> napisał(a):

Dear Finder

Thanks for sending this across to us, appreciate your effort.

But our team couldn't reproduce the finding with the README instructions. Could you provide a video repro showing how to reproduce this from scratch, starting from a computer without the PoC installed?

Regards

MSRC

----- Original Message -----

From: Microsoft Security Response Center

Received: Fri Aug 05 2022 21:42:25 GMT+0530 (India Standard Time)

To: kroppoloe@protonmail.ch

Subject: MSRC Case 73588 CRM:0022008796

Thank you for contacting the Microsoft Security Response Center (MSRC). I've opened a case for this issue:

MSRC Case 73588

Please use this email thread--do not modify or remove the "CRM" token in the subject line--for all communication about this case. Also, please keep the details of this case confidential during our investigation. For more information, please see below:

Microsoft's Approach to Coordinated Vulnerability Disclosure

<https://www.microsoft.com/en-us/msrc/cvd>

Microsoft Bug Bounty Program

<https://www.microsoft.com/en-us/msrc/bounty>

Acknowledgements

<https://portal.msrmicrosoft.com/en-us/security-guidance/acknowledgments>

Online Service Acknowledgements

<https://portal.msrmicrosoft.com/en-us/security-guidance/researcher-acknowledgments-online-services>

MSRC